



Information Gathering

Introduction

Alexis Ahmed

Senior Penetration Tester @HackerSploit
Offensive Security Instructor @INE



aahmed@ine.com



@HackerSploit



@alexisahmed

Course Topic Overview

- + Introduction To Information Gathering
- + Passive Information Gathering
- + Active Information Gathering

- + Basic familiarity with Linux
- + Basic familiarity with web technologies

Prerequisites



Learning Objectives:

- Students will learn about the difference between active and passive information gathering.
- Students will learn how to perform passive information gathering by leveraging various tools and resources.
- Students will perform active information gathering.

Disclaimer

In this module you will see some examples of tools and techniques used on realistic IP addresses and hosts.

Never run any of these tools and techniques on those addresses or on any machine and network without proper authorization!



Let's Get Started!



Introduction To Information Gathering

What is Information Gathering?

- Information gathering is the first step of any penetration test and involves gathering or collecting information about an individual, company, website or system that you are targeting.
- The more information you have on your target, the more successful you will be during the latter stages of a penetration test.
- Information gathering is typically broken down into two types:
 - Passive information gathering - Involves gathering as much information as possible without actively engaging with the target.
 - Active information gathering - Involves gathering as much information as possible by actively engaging with the target system. (You will require authorization in order to perform active information gathering)

What Information Are We Looking For?

Passive Information Gathering

- + Identifying IP addresses & DNS information.
- + Identifying domain names and domain ownership information.
- + Identifying email addresses and social media profiles.
- + Identifying web technologies being used on target sites.
- + Identifying subdomains.

Active Information Gathering

- + Discovering open ports on target systems.
- + Learning about the internal infrastructure of a target network/organization.
- + Enumerating information from target systems.



Target Scoping

Target Scoping

Lesson Objective

By the end of this lesson, you will understand:

- + What target scoping means in a penetration test
- + How to identify what is in scope and out of scope

What is Target Scoping?

- + Target scoping is the process of defining exactly what systems, networks, or applications you are allowed to test.
- + In a penetration test, you are not testing “everything you can find.”
- + You are testing only what has been explicitly authorized.
- + Fundamentally, in the context of information gathering, scoping answers one simple question:

What am I allowed to collect information about?

Common Types of Targets

During reconnaissance, targets are usually defined in one or more of the following ways:

Domain-Based Targets

Examples:

- + example.com
- + testsite.local

A domain-based scope may include:

- + The primary domain
- + Subdomains (e.g., mail.example.com, admin.example.com)

Common Types of Targets

IP-Based Targets

Examples:

- + A single IP address: 192.168.1.10
- + A network range: 192.168.1.0/24

IP-based scopes are common in internal or lab-based environments.

Common Types of Targets

Application-Based Targets

Examples:

- + A specific web application
- + A login portal or API endpoint

In this case, reconnaissance focuses on that application only, not the entire server.

Scope

In-Scope

Assets you are allowed to:

- + Collect information from
- + Scan
- + Enumerate

Out-of-Scope

Assets you must not interact with.

Examples:

- + Third-party services
- + External domains not listed in scope
- + Systems owned by another organization

Why Scoping Matters

Reconnaissance is about collecting useful information, not collecting all information.

- + Without proper scoping:
 - + You may scan irrelevant hosts
 - + You may miss the actual target
 - + Your results become noisy and confusing

- + A well-defined scope keeps your reconnaissance:
 - + Focused
 - + Efficient
 - + Relevant to later stages



Passive vs Active Reconnaissance

Passive vs Active Reconnaissance

Lesson Objective

By the end of this lesson, you will understand:

- + The difference between passive and active reconnaissance
- + A simple, repeatable reconnaissance strategy to follow before using tools
- + This lesson focuses on methodology, not tools.

Passive vs Active Reconnaissance

- + Reconnaissance techniques fall into two main categories:
 - + Passive
 - + Active

Passive Information Gathering

Passive reconnaissance involves collecting information without directly interacting with the target systems.

Characteristics:

- + No direct connection to target servers
- + Low risk of detection
- + Usually performed first

Examples of passive recon data:

- + Domain registration information
- + DNS records
- + Public website content
- + Search engine results
- + Publicly available email addresses

Active Information Gathering

Active reconnaissance involves direct interaction with target systems.

Characteristics:

- + Sends traffic to the target
- + Increased visibility
- + Typically performed after passive recon

Examples of passive recon data:

- + Live hosts
- + Open ports
- + Running services
- + Network responses

**Always start with passive reconnaissance
before moving to active reconnaissance.**

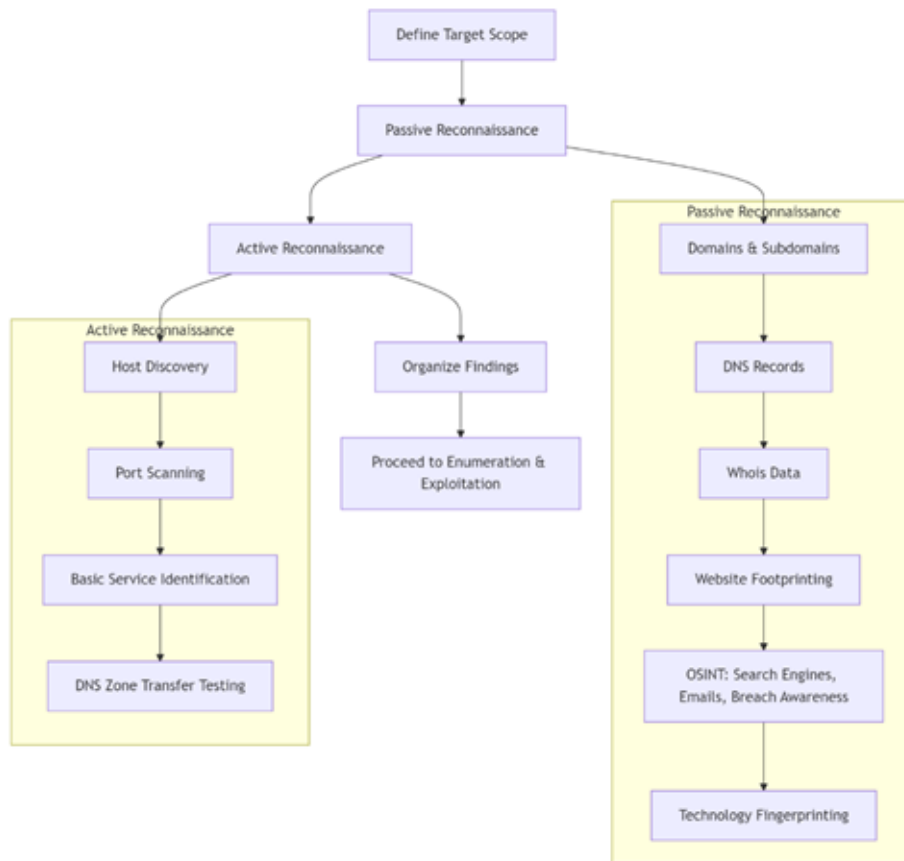


What Information Are We Trying To Collect?

During information gathering, your goal is to build a map of the target.

- + Domains and subdomains
- + IP addresses
- + Hosting infrastructure
- + Technologies and services
- + Open ports
- + Publicly exposed information

Typical Recon Mapping Flow



Recon Strategy

Use the following four-step strategy during every engagement.

Step 1: Define the Target

- + Identify the domain, IP address, or network range
- + Confirm what is in scope

Step 2: Perform Passive Reconnaissance

- + Gather public information
- + Identify potential attack surfaces
- + Build initial understanding of the target

Recon Strategy

Use the following four-step strategy during every engagement.

Step 3: Perform Active Reconnaissance

- + Discover live hosts
- + Identify open ports
- + Detect exposed services

Step 4: Document & Organize Your Findings

- + Record domains, IPs, and ports
- + Prepare information for enumeration
- + Avoid repeating work later

Common Mistakes

The following are mistakes frequently made by beginners:

- + Starting scans without defining scope
- + Skipping passive reconnaissance
- + Scanning everything instead of relevant targets
- + Not documenting results
- + Trusting tool output without verification
- + Avoiding these mistakes will save time and improve accuracy.

Key Takeaways

- + Target scoping defines what you are allowed to test
- + Passive recon comes before active recon
- + Reconnaissance is about collecting meaningful data
- + A structured approach improves results and efficiency



Website Recon & Footprinting

What are we looking for

- + IP addresses
- + Directories hidden from search engines
- + Names
- + Email addresses
- + Phone Numbers
- + Physical Addresses
- + Web technologies being used



Practical Demo



Whois Enumeration



Practical Demo



Website Footprinting With Netcraft



Practical Demo



DNS Recon



Practical Demo



WAF Detection With wafw00f



Practical Demo



Subdomain Enumeration With Sublist3r



Practical Demo



Google Dorks



Practical Demo



Email Harvesting With theHarvester



Practical Demo



Leaked Password Databases



Practical Demo



DNS Zone Transfers

DNS

- + Domain Name System (DNS) is a protocol that is used to resolve domain names/hostnames to IP addresses.
- + During the early days of the internet, users would have to remember the IP addresses of the sites that they wanted to visit, DNS resolves this issue by mapping domain names (easier to recall) to their respective IP addresses.
- + A DNS server (nameserver) is like a telephone directory that contains domain names and their corresponding IP addresses.
- + A plethora of public DNS servers have been set up by companies like Cloudflare (1.1.1.1) and Google (8.8.8.8). These DNS servers contain the records of almost all domains on the internet.

DNS Records

- + A - Resolves a hostname or domain to an IPv4 address.
- + AAAA - Resolves a hostname or domain to an IPv6 address.
- + NS - Reference to the domains nameserver.
- + MX - Resolves a domain to a mail server.
- + CNAME - Used for domain aliases.
- + TXT - Text record.
- + HINFO - Host information.
- + SOA - Domain authority.
- + SRV - Service records.
- + PTR - Resolves an IP address to a hostname

DNS Interrogation

- + DNS interrogation is the process of enumerating DNS records for a specific domain.
- + The objective of DNS interrogation is to probe a DNS server to provide us with DNS records for a specific domain.
- + This process can provide with important information like the IP address of a domain, subdomains, mail server addresses etc.

DNS Zone Transfer

- + In certain cases DNS server admins may want to copy or transfer zone files from one DNS server to another. This process is known as a zone transfer.
- + If misconfigured and left unsecured, this functionality can be abused by attackers to copy the zone file from the primary DNS server to another DNS server.
- + A DNS Zone transfer can provide penetration testers with a holistic view of an organization's network layout.
- + Furthermore, in certain cases, internal network addresses may be found on an organization's DNS servers.



Practical Demo



Host Discovery With Nmap



Practical Demo



Port Scanning With Nmap



Practical Demo



Information Gathering

Conclusion



Learning Objectives:

- Students will learn about the difference between active and passive information gathering.
- Students will learn how to perform passive information gathering by leveraging various tools and resources.
- Students will perform active information gathering.



Thank You!